

Blockchain-Based Secure Platform for Identity, Access Control, and Digital Asset Management

Problem & Gap Analysis Document

Organization: Bharat Electronics Limited (BEL) | Theme: Blockchain & Cybersecurity

This document consolidates every problem our team has identified for PS 26125 — both the problems explicitly named in the official problem statement, and the additional, unstated architectural and security flaws that are inherent to any system built the way BEL has described it. For each problem we state what it is, how it actually manifests (the failure mode), and the mitigation our solution will implement. The final section covers our forward-looking roadmap, including post-quantum cryptographic readiness.

1. Problems Explicitly Stated in the Official Problem Statement

These are the baseline issues named directly by BEL in PS 26125. Every competing team is expected to address these; we treat them as the minimum bar.

Stated Problem	What It Means / How It Manifests	Our Mitigation
Centralized IAM = single point of failure	One compromised database or server can bring down identity verification and access control for the entire organization at once.	Decentralized Identifiers (DIDs) anchored on-chain; no single server holds the master identity record.
Vulnerable to cyberattacks & identity theft	Centralized credential stores (password DBs) are high-value breach targets; stolen credentials = stolen identity.	Cryptographic key-pair authentication (challenge-response signatures) replaces passwords entirely.
Unauthorized access	Manual or loosely enforced permission checks can be bypassed or misconfigured by human error.	Role-Based Access Control enforced automatically inside smart contracts — no manual override path.
Disconnected / semi-centralized asset ownership records	Ownership history lives in silos (spreadsheets, separate DBs per department); no single source of truth.	All assets minted as NFTs on one shared ledger, directly linked to the owning DID.
Ownership & authenticity hard to verify	No cryptographic proof chain; verification depends on trusting whichever system is asked.	On-chain provenance: every mint, transfer, and permission change is independently verifiable by anyone with read access.

2. Additional Problems We Identified (Not Stated in the PS)

These are real architectural, security, and governance flaws that exist in the system BEL has described, even though the problem statement does not mention them. Identifying and mitigating these is what will differentiate our submission.

2.1 Identity (DID) Layer

2.1.1 Private Key Loss = Permanent Identity Loss

Problem: A DID's authority rests entirely on a private key. There is no 'forgot password' option.

How it manifests: An employee loses their device or key file → they are permanently locked out of their identity, and any assets/roles tied to it become inaccessible. For an org the size of BEL, this is an operational catastrophe, not an edge case.

Our mitigation: Guardian-based social recovery (M-of-N trusted guardians — e.g., HR + IT admin + a second manager — can jointly authorize key rotation for a locked-out identity, without any single guardian having unilateral control).

2.1.2 Sybil Attacks on Identity Issuance

Problem: Nothing inherently stops one person from generating many DIDs to appear as multiple distinct users.

How it manifests: An attacker could create multiple fake identities to manipulate role assignment, approval quorums, or audit-trail analysis.

Our mitigation: DID issuance gated behind a verified onboarding step (org-issued Verifiable Credential at creation time) — a DID is only valid if it carries a credential signed by an authorized BEL issuer.

2.1.3 On-Chain Identity Does Not Prove Real-World Identity

Problem: A DID proves control of a key, not that the key belongs to a specific, authorized human.

How it manifests: 'Identity theft' is not eliminated — it is just relocated to the credential-issuance step, which the base PS never addresses.

Our mitigation: Verifiable Credentials (W3C VC standard) issued only after an authenticated onboarding process, cryptographically binding the DID to an organizationally-verified identity.

2.1.4 Permanent Public Correlation / Privacy Leakage

Problem: Every action tied to a DID is public and permanent — full activity history is traceable forever.

How it manifests: Over time, anyone can build a complete behavioral profile of any user — a privacy regression compared to a properly access-controlled centralized DB.

Our mitigation: Selective disclosure via zero-knowledge proofs — a user proves 'I hold role X' or 'I am authorized for asset Y' without revealing their full DID history.

2.2 Smart Contract & Access Control Layer

2.2.1 Admin Key Compromise = Full System Takeover

Problem: RBAC is enforced by smart contracts, but if the Admin's private key is stolen, the attacker instantly inherits full Admin power — mint NFTs, reassign roles — with no lockout mechanism.

How it manifests: This is arguably worse than the centralized single-point-of-failure the PS is trying to eliminate, because on-chain actions by a compromised admin key are irreversible.

Our mitigation: Multi-signature (M-of-N) approval required for high-privilege actions (minting, role escalation); emergency Pausable circuit-breaker contract that can freeze all privileged operations the moment a compromise is detected.

2.2.2 No Instant Revocation

Problem: Static, always-on RBAC has no built-in urgency handling for an employee who is fired or a key that is compromised.

How it manifests: Blockchain transactions have confirmation latency and gas cost — 'immediate' revocation is not actually immediate unless explicitly engineered.

Our mitigation: Time-bound, auto-expiring permissions (roles carry a validity window and expire on-chain automatically) plus a priority emergency-revocation function callable by any two Admins.

2.2.3 Irreversible Smart Contract Bugs

Problem: Unlike centralized software, a bug in a deployed contract cannot simply be patched — historical exploits (The DAO, Parity multisig freeze) show this is a real, not theoretical, risk.

How it manifests: A single logic flaw in the RBAC or minting contract could freeze or drain the entire asset registry permanently.

Our mitigation: Upgradeable proxy pattern (OpenZeppelin UUPS/Transparent Proxy) + independent audit checklist + Pausable emergency stop, so logic can be fixed without losing on-chain state.

2.2.4 Gas Cost & Scalability Bottleneck

Problem: Every identity creation, NFT mint, and role change is an on-chain transaction with real cost — the PS implicitly assumes unlimited on-chain write capacity.

How it manifests: At organizational scale (thousands of employees / assets), transaction cost and network congestion become real operational blockers, not edge cases.

Our mitigation: Layer-2 rollup deployment (e.g., Polygon) for day-to-day operations, batched/rolled-up to a base chain periodically; off-chain signing with on-chain settlement where possible.

2.2.5 Oracle / Off-Chain Trust Gap

Problem: Any real-world event that must trigger an on-chain action (e.g., 'this physical asset was delivered') requires an oracle — a known, exploitable trust boundary.

How it manifests: A manipulated or unavailable oracle can falsify the very facts the blockchain is supposed to guarantee are true.

Our mitigation: Decentralized oracle design with multiple independent attestors and a dispute window before an oracle-fed fact becomes final on-chain.

2.3 NFT / Digital Asset Layer

2.3.1 NFT Ownership ≠ Legal Ownership

Problem: A token proving 'this address holds NFT #X' has no automatic legal enforceability unless explicitly bridged to a recognized legal framework.

How it manifests: The system can guarantee cryptographic uniqueness while still being legally meaningless in a dispute, since Indian law does not yet universally recognize on-chain records as title.

Our mitigation: Design the NFT metadata schema to be compatible with a legal-bridge document (a signed attestation referencing the NFT) so it can be adopted as recognized evidence once regulation catches up; flag this explicitly as a known limitation in our documentation rather than overclaiming.

2.3.2 Off-Chain Metadata Rot

Problem: If NFT metadata (documents, images, descriptions) is stored as a plain URL rather than content-addressed storage, the pointer can silently break or be altered while the token itself looks 'immutable.'

How it manifests: An attacker or even simple link rot can change what an NFT actually 'represents' without any on-chain trace.

Our mitigation: All metadata pinned to IPFS (or Filecoin) and referenced on-chain by content hash, so any tampering is instantly detectable.

2.3.3 Real-World Asset Authenticity (Oracle Problem for Physical Assets)

Problem: The blockchain guarantees a token is unique — it does not guarantee the real-world asset behind it actually exists or is correctly described.

How it manifests: Nothing stops someone minting an NFT for an asset they don't actually possess or control.

Our mitigation: Mandatory dual-attestation minting — a physical/digital asset can only be minted after two independent authorized roles (e.g., Manager + Auditor) confirm its existence, not a single Admin acting alone.

2.4 Systemic & Governance Layer

2.4.1 'Who Watches the Admin?'

Problem: RBAC assumes Admins are trustworthy by definition — the PS's own premise (distrust centralized authority) applies equally to on-chain Admins.

How it manifests: Without checks, we've simply relocated the single point of failure from 'the database' to 'the Admin's private key' — not actually solved it.

Our mitigation: Multi-signature governance for Admin-level actions (Section 2.2.1) + a transparent, publicly auditable log of every Admin action, so misuse is provable even if not preventable in real time.

2.4.2 No Dispute Resolution Mechanism

Problem: If an NFT is wrongly transferred or a role wrongly assigned, blockchain immutability becomes a liability — there's no built-in way to reverse a fraudulent-but-valid-looking transaction.

How it manifests: A social-engineering attack that tricks a legitimate Admin into signing a bad transaction becomes permanent and unfixable by default.

Our mitigation: A time-locked 'cooling-off' window on high-value transfers, during which a multi-party dispute/veto process can freeze and reverse the action before it finalizes.

2.4.3 Regulatory & Compliance Blindness

Problem: As a defense-sector PSU, BEL is subject to data localization rules and classified-information handling norms that a naive public-chain deployment ignores entirely.

How it manifests: A prototype built purely on a public testnet cannot realistically be deployed as-is in a defense/PSU environment.

Our mitigation: Recommend and design for a permissioned/consortium chain (e.g., Hyperledger Fabric or a private Polygon Edge network) as the realistic production target, with our public-testnet build serving as the functional proof of concept.

3. Future Scope

Beyond the MVP, the following roadmap items address longer-horizon risks and capability gaps. These are presented as planned future work, not claimed as part of the current build.

3.1 Quantum Computing Threat (Highest Priority Long-Term Risk)

- Current blockchain signature schemes (ECDSA, used by Ethereum and most DID methods) are provably breakable by Shor's algorithm on a sufficiently powerful quantum computer.
- Because on-chain data is public and permanent, this creates a 'harvest now, decrypt later' risk today: an adversary can record current signatures/public keys now and forge or break them retroactively once quantum computers mature — years before quantum computing is practical, the exposure already exists.
- Planned mitigation: design the identity and signing layer to be crypto-agile — signature verification logic sits behind an upgradeable contract interface so the underlying scheme can be swapped without migrating the whole identity graph.
- Target future algorithms: NIST-standardized post-quantum schemes — CRYSTALS-Dilithium (signatures) and CRYSTALS-Kyber (key exchange), finalized by NIST in 2024.
- Track and adopt emerging W3C research on quantum-resistant DID methods as the standard matures.

3.2 AI-Based Anomaly Detection

- Off-chain monitoring service watching on-chain events in real time to flag suspicious patterns — mass transfers, rapid role escalation, unusual admin activity — feeding into the audit trail as risk-scored alerts.

3.3 Cross-Chain / Inter-Organization Interoperability

- Bridging identity and asset records across multiple government/PSU chains (e.g., BEL, DRDO, other defense PSUs) so a DID or credential issued in one system is portable and verifiable in another.

3.4 Biometric-Bound Identity

- Binding a DID to a hashed biometric proof (fingerprint/iris template hash, never raw biometric data) for stronger real-world identity binding, directly addressing the 'DID ≠ real identity' gap in Section 2.1.3.

3.5 Zero-Knowledge Compliance Proofs

- Allow the organization to prove regulatory or policy compliance (e.g., data-localization adherence) to an external auditor without exposing the underlying sensitive records.

3.6 Layer-2 Scaling Maturity

- As adoption grows beyond pilot scale, migrate high-frequency operations to rollups or a dedicated app-chain to keep transaction costs and latency low.

3.7 Legal-Tech Bridge

- Engage with evolving Indian digital-asset regulation to give on-chain ownership records recognized legal standing, closing the gap identified in Section 2.3.1.

4. Summary

Our submission addresses PS 26125 at two levels: (1) the problems BEL explicitly named — centralization risk, identity theft, unauthorized access, and disconnected/unverifiable ownership — and (2) the deeper architectural flaws inherent to any DID + NFT + RBAC system that the problem statement does not mention, spanning identity recovery, admin-key compromise, contract upgradeability, off-chain trust gaps, legal enforceability, and long-term cryptographic risk from quantum computing. Presenting both layers — and a credible, staged mitigation plan for each — is the core differentiator of our approach.